

ОБНАРУЖЕНИЕ И КЛАССИФИКАЦИЯ КИБЕРАТАК НА ОСНОВЕ КОМПЛЕКСНОГО АНАЛИЗА СЕТЕВОГО ТРАФИКА И ЖУРНАЛОВ СОБЫТИЙ: МЕТОДИКА ФОРМИРОВАНИЯ ОБУЧАЮЩИХ ДАННЫХ И НАБОРА ДЕТЕКТИРУЕМЫХ ШАБЛОНОВ

А.П. Васильченко, Е.А. Попова, Н.П. Жуков, С.Е. Сотников

В статье рассматривается задача формирования обучающих данных для систем автоматизированного обнаружения и классификации кибератак на основе комплексного анализа сетевого трафика и журналов событий. Предложена методика отбора и структурирования детектируемых шаблонов атак с использованием таксономии CAPEC, обеспечивающая формализацию процессов разметки данных и определение границ применимости системы. Обосновано разграничение шаблонов CAPEC на используемые для обучения моделей машинного обучения и выявляемые программными методами анализа событийных данных. Показано, что сформированный набор детектируемых шаблонов охватывает около 40 % перечня CAPEC и позволяет сформировать воспроизводимый обучающий набор, ориентированный на интерпретируемое и сценарно-ориентированное выявление кибератак.

Ключевые слова: обнаружение атак, классификация атак, сетевой трафик, журналы событий, CAPEC, обучающие данные.

Введение

Современные информационные системы функционируют в условиях постоянного роста сложности и разнообразия киберугроз, обусловленного развитием распределённых архитектур, облачных технологий и увеличением объёмов сетевого взаимодействия. Атакующие сценарии всё чаще носят многоэтапный характер и включают в себя как сетевые воздействия, так и действия, реализуемые на уровне операционных систем и прикладных сервисов. В таких условиях задача обнаружения и классификации кибератак требует использования методов, способных учитывать совокупность разнородных проявлений атакующего поведения [1].

Целью настоящей статьи является разработка и обоснование методики формирования обучающих данных и набора детектируемых шаблонов CAPEC для задач обнаружения и классификации кибератак на основе комплексного анализа сетевого трафика и журналов событий. Предлагаемый подход ориентирован на совместное использование моделей машинного обучения и программных методов анализа событийных данных и направлен на повышение полноты и

интерпретируемости выявляемых атакующих сценариев.

Актуальность поставленной цели определяется следующими основными противоречиями, выявленными в ходе анализа существующих подходов к обнаружению кибератак:

- между необходимостью комплексного анализа сетевого трафика и журналов регистрации событий и ориентацией большинства существующих систем обнаружения атак на обработку одного источника данных;

- между необходимостью идентификации атак в соответствии с таксономией CAPEC и отсутствием такого функционала у большинства существующих аналогов.

Указанные противоречия обуславливают необходимость разработки методики, обеспечивающей осознанный отбор источников данных, формирование репрезентативных обучающих наборов и структурирование шаблонов атак с учётом способов их практического применения.

Для достижения поставленной цели в статье решаются следующие основные задачи:

1) разработать принципы формирования обучающих данных для анализа сетевого трафика и набора шаблонов CAPEC, используемых для программного анализа событийных данных;

2) обосновать методику отбора и разграничения шаблонов CAPEC в зависимости от способа их использования при обучении модели и при программном анализе событийных данных.

Использование таксономии CAPEC для формализованного описания атакующих сценариев

Важным этапом формирования обучающих данных для задач обнаружения и классификации кибератак является выбор формализованной модели, позволяющей описывать атакующие воздействия в виде унифицированных и интерпретируемых шаблонов. В рамках данной работы в качестве такой модели используется таксономия CAPEC (Common Attack Pattern Enumeration and Classification), представляющая собой структурированный реестр типовых атакующих сценариев [2].

Таксономия CAPEC обеспечивает описание атак с точки зрения целей злоумышленника, характерных этапов реализации, условий успешности и возможных точек наблюдения. В отличие от подходов, ориентированных на фиксацию отдельных технических событий, CAPEC рассматривает атаку как последовательность логически связанных действий, что делает данную таксономию особенно удобной для анализа сложных и многоэтапных сценариев [2].

Использование CAPEC позволяет сопоставлять разрозненные сетевые события и записи журналов регистрации с типовыми моделями поведения злоумышленника. Это имеет принципиальное значение при комплексном анализе данных, получаемых из независимых источников, таких как сетевой трафик и журналы событий, и обеспечивает единый семантический контекст при интерпретации наблюдаемых признаков [2].

В практическом аспекте таксономия CAPEC применяется для отбора тех атакующих сценариев, признаки которых могут быть зафиксированы доступными техническими средствами мониторинга.

Такие сценарии формируют набор детектируемых шаблонов атак, пригодных для включения в обучающий набор данных. Одновременно использование CAPEC позволяет идентифицировать сценарии, признаки которых либо слабо выражены, либо принципиально недоступны для наблюдения в рамках используемых источников данных, например атаки, полностью маскирующиеся в зашифрованных каналах или требующие внешней разведывательной информации. Подобные сценарии относятся к недетектируемым шаблонам и не рассматриваются при формировании обучающей выборки, определяя границы применимости разрабатываемой системы [1].

Анализ открытых датасетов для задач обнаружения и классификации кибератак по данным сетевого трафика

Разработка систем обнаружения и классификации кибератак, основанных на методах машинного обучения, требует использования качественных, репрезентативных и корректно размеченных наборов данных. В связи с этим в исследовательской практике сформировался ряд открытых датасетов сетевого трафика, широко применяемых в качестве эталонной базы для тестирования и сравнения алгоритмов обнаружения атак. Каждый из таких наборов данных создавался в рамках определённых исследовательских задач и отражает особенности конкретной моделируемой сетевой среды, что обуславливает существенные различия в составе трафика, структуре признаков и номенклатуре атакующих сценариев. Анализ наиболее распространённых датасетов необходим для оценки их применимости в рамках настоящего исследования и обоснованного выбора источника обучающих данных [3].

Одним из наиболее ранних и широко используемых является датасет CICIDS2017, опубликованный Канадским институтом кибербезопасности в 2017 году. Он включает порядка 2,8 млн записей сетевого трафика, из которых значительная часть относится к легитимной активности. Датасет формировался в условиях моделируемой

корпоративной сети и охватывает широкий спектр атак типа DoS/DDoS, сценарии перебора учётных данных и ограниченное число прикладных угроз. Структура

CICIDS2017 приведена в табл. 1, где особенно заметна вариативность семейств DoS/DDoS-атак [4].

Таблица 1

Структура и распределение классов атак в датасете CICIDS2017

Класс	Значение класса	Количество записей	Описание
BENIGN	Легитимный сетевой трафик	2 273 097	Нормальные прикладные и системные соединения без признаков нарушения политик безопасности или эксплуатации уязвимостей
DoS Hulk	Высокоинтенсивная DoS-атака типа Hulk	231 073	Генерация большого числа HTTP-запросов с целью исчерпания ресурсов веб-сервера и нарушения его работоспособности
PortScan	Сетевое сканирование портов	158 930	Последовательные попытки установления соединения с широким диапазоном портов для выявления открытых сервисов и построения карты инфраструктуры
DDoS	Распределённая DoS-атака	128 027	Масштабированная перегрузка сети или сервиса за счёт одновременной генерации трафика с множества узлов
DoS GoldenEye	DoS-атака GoldenEye	10 293	Использование специфического шаблона HTTP-запросов для постепенного истощения ресурсов веб-сервера
FTP-Patator	Грубый подбор для FTP	7 938	Многочисленные попытки аутентификации к FTP-серверу с перебором пар логин/пароль
SSH-Patator	Грубый подбор для SSH	5 897	Автоматизированные попытки получения доступа к SSH-сервису путём систематического перебора учётных данных
DoS Slowloris	Медленная DoS-атака Slowloris	5 796	Удержание большого числа неполных HTTP-соединений с целью блокирования новых запросов
DoS SlowHTTPTest	Медленная HTTP-атака	5 499	Формирование неполных или замедленных HTTP-запросов для удержания серверных ресурсов
Bot	Ботнет-активность	1 966	Трафик от узлов, находящихся под управлением злоумышленника и выполняющих команды управления
Web-Bruteforce	Подбор учётных данных в веб-приложениях	1 507	Серии запросов к веб-формам аутентификации с перебором комбинаций логин/пароль
Infiltration	Сетевое проникновение	36	Сценарии доставки и активации вредоносного ПО с закреплением во внутреннем сегменте сети
SQL Injection	SQL-инъекции	21	Модификация параметров SQL-запросов для обхода контроля доступа или изменения данных
Heartbleed	Эксплуатация уязвимости Heartbleed	11	Специально сформированные запросы к уязвимым реализациям OpenSSL, приводящие к утечке памяти

Благодаря детализированной системе сетевой среде CICIDS2017 стал ориентиром признаков и относительно реалистичной для последующих исследований. В то же

время выраженный дисбаланс классов и крайне низкое представление отдельных типов атак существенно затрудняют обучение устойчивых многоклассовых классификаторов. Кроме того, ряд угроз, актуальных для современных сетевых инфраструктур, в данном датасете отсутствует [4].

Дальнейшее развитие данной линейки получило отражение в датасете CICIDS2018,

опубликованном в 2018 году. Он отличается увеличенным объёмом данных и более длительными временными сессиями и содержит около 16,2 млн записей сетевого трафика. Структура датасета представлена в табл. 2 и демонстрирует значительное преобладание легитимной активности [3].

Таблица 2

Структура и распределение классов атак в датасете CICIDS2018

Класс	Значение класса	Количество записей	Описание
Benign	Легитимный сетевой трафик	13 484 753	Сетевые соединения и запросы, соответствующие штатной эксплуатации информационных систем и не содержащие признаков вредоносной активности
DDoS	Распределённые атаки отказа в обслуживании	1 263 901	Координированные воздействия с множества узлов-источников, направленные на исчерпание вычислительных и сетевых ресурсов целевого сервиса и нарушение его доступности
DoS	Локальные атаки отказа в обслуживании	654 352	Вредоносные действия одного или ограниченного числа источников, приводящие к перегрузке канала или сервисов и временному нарушению их работоспособности
Brute Force	Атаки грубого подбора учётных данных	380 989	Серии автоматизированных попыток аутентификации с перебором паролей и иных реквизитов доступа к прикладным сервисам
Botnet	Ботнет-ориентированная вредоносная активность	286 188	Трафик от узлов, находящихся под внешним управлением и используемых для проведения атак, рассылки спама и организации распределённых воздействий
Infiltration	Атаки проникновения во внутреннюю инфраструктуру	161 843	Сетевые взаимодействия, связанные с доставкой и активацией вредоносного программного обеспечения, закреплением в системе и скрытым управлением
Web attack	Атаки на веб-приложения	9 740	Попытки эксплуатации уязвимостей веб-приложений (SQL-инъекции, XSS и др.), направленные на обход механизмов контроля и получение несанкционированного доступа

CICIDS2018 характеризуется высокой реалистичностью фонового трафика и расширенным набором распространённых угроз. Однако, как и предыдущая версия, он сохраняет выраженный дисбаланс классов, при котором легитимный трафик занимает более 80 % выборки, а некоторые атакующие сценарии представлены минимально. Это

ограничивает возможности применения датасета в задачах многоклассовой классификации, хотя делает его полезным для исследований бинарного обнаружения аномалий [3].

В конце 2018 года был представлен датасет CSE-CIC-IDS2018, разработанный на основе сценариев CICIDS2017 и CICIDS2018.

Он ориентирован на повышение согласованности данных, расширение спектра атак и формирование более строгой экспериментальной среды. Общий объём полной версии датасета составляет порядка 16 млн записей. Как показано в табл. 3, CSE-

CIC-IDS2018 содержит более детализированное представление семейств DoS/DDoS-атак, что повышает его ценность при анализе поведенческих характеристик сетевых перегрузок [3].

Таблица 3

Структура и распределение классов атак в датасете CSE-CIC-IDS2018

Класс	Значение класса	Количество записей	Описание
Benign	Легитимный сетевой трафик	1 347 953	Обычные пользовательские и служебные соединения, соответствующие штатному режиму работы инфраструктуры
HOIC	DDoS-атака HOIC	68 821	Высокообъёмные HTTP-атаки, генерируемые инструментом High Orbit Ion Cannon и направленные на отказ в обслуживании веб-ресурсов
LOIC-HTTP	DDoS-атака LOIC по HTTP	57 550	Нагрузочные атаки с использованием Low Orbit Ion Cannon, ориентированные на перегрузку веб-сервиса многочисленными HTTP-запросами
DoS Hulk	DoS-атака Hulk	46 014	Генерация большого количества запросов к веб-серверу с целью истощения процессорных и сетевых ресурсов
Bot	Ботнет-активность	28 539	Узлы, управляемые с внешнего центра и участвующие в распределённых атаках и других вредоносных операциях
FTP-Bruteforce	Грубый подбор для FTP	19 484	Автоматизированный перебор параметров аутентификации к FTP-серверу
SSH-Bruteforce	Грубый подбор для SSH	18 485	Систематический перебор учётных данных при подключении по протоколу SSH
Infiltration	Проникновение	16 160	Сетевые взаимодействия, связанные с загрузкой, установкой и эксплуатацией вредоносного ПО внутри сети
SlowHTTPTest	Медленные HTTP-атаки	14 110	Использование намеренно замедленных или фрагментированных HTTP-запросов для удержания ресурсов сервера
GoldenEye	DoS-атака GoldenEye	4 154	Комплексные HTTP-атаки, имитирующие легитимную активность и затрудняющие фильтрацию
Slowloris	DoS-атака Slowloris	1 076	Удержание большого числа полуоткрытых соединений, блокирующих обработку новых запросов
LOIC-UDP	DDoS-атака LOIC по UDP	163	Массовая генерация UDP-пакетов с целью перегрузки канала связи или сетевых устройств
Web-Bruteforce	Подбор учётных данных веб-приложений	59	Многочисленные запросы к формам аутентификации веб-приложений
XSS	Межсайтовый скриптинг	25	Встраивание вредоносного сценарного кода в веб-страницы
SQL Injection	SQL-инъекции	7	Эксплуатация уязвимостей обработки входных данных в СУБД

Несмотря на более аккуратную структуру и расширенное описание атакующих сценариев, данный датасет по-прежнему сохраняет ограничения, связанные с недостаточным представлением редких атак и ограниченной вариативностью современного трафика.

Значимым этапом в развитии экспериментальных данных для IDS стал

датасет UNSW-NB15, разработанный в Australian Centre for Cyber Security с использованием аппаратного генератора трафика IXIA PerfectStorm. Такой подход обеспечил высокое качество моделируемых сетевых воздействий. Структура датасета приведена в табл. 4 и отражает наличие как прикладных, так и протокольных атак [5].

Таблица 4

Структура и распределение классов атак в датасете UNSW-NB15

Класс	Значение класса	Количество записей	Описание
Normal	Легитимный сетевой трафик	2 218 761	Набор записей, характеризующих нормальные операции сетевых служб и пользователей без признаков атак
Fuzzers	Генерация тестовых воздействий	24 246	Попытки вызвать некорректное поведение приложений и протоколов путём подачи случайно сгенерированных или заведомо ошибочных данных
Analysis	Аналитическая активность	2 677	Трафик, связанный с различными формами технического анализа и тестирования, включая сканирование и диагностику
Backdoors	Закладочные механизмы	2 329	Попытки скрытого удалённого управления системой через заранее подготовленные механизмы обхода аутентификации
DoS	Атаки отказа в обслуживании	16 353	Вредоносные воздействия, направленные на исчерпание ресурсов и ухудшение доступности сетевых и прикладных сервисов
Exploits	Эксплуатация уязвимостей	44 525	Сетевые взаимодействия, инициирующие выполнение вредоносного кода или несанкционированные операции за счёт уязвимостей программного обеспечения
Generic	Универсальные криптографические атаки	215 481	Воздействия на криптографические механизмы и протоколы, не привязанные к конкретному приложению
Reconnaissance	Разведывательная активность	13 987	Сбор информации о структуре сети, активных узлах и доступных сервисах на подготовительном этапе атаки
Shellcode	Внедрение shell-кода	1 511	Передача и исполнение компактных фрагментов машинного кода, обеспечивающих атакующему дальнейший контроль
Worms	Компьютерные черви	174	Самораспространяющиеся вредоносные программы, использующие сетевые уязвимости для заражения новых узлов

Благодаря более равномерному распределению классов и включению разнообразных угроз UNSW-NB15 получил широкое распространение при обучении

универсальных моделей обнаружения атак. Вместе с тем он отражает состояние киберугроз на момент создания и не включает сценарии, характерные для современных

облачных и контейнеризированных архитектур [5].

С ростом числа IoT-устройств возникла необходимость моделирования атак, специфичных для данной среды. В ответ на

это был разработан датасет BoT-IoT, включающий около 73 млн записей сетевого трафика. Его структура представлена в табл. 5 [6].

Таблица 5

Структура и распределение классов атак в датасете BoT-IoT

Класс	Значение класса	Количество записей	Описание
Service scanning	Сканирование сетевых сервисов	1 463 364	Активность по выявлению доступных сервисов и их характеристик в целях последующей эксплуатации выявленных уязвимостей
OS Fingerprinting	Определение характеристик операционной системы	358 275	Специфические запросы и ответы, позволяющие идентифицировать тип и версию операционной системы целевого узла
DDoS	Распределённые атаки отказа в обслуживании	39 729 480	Масштабные воздействия на инфраструктуру IoT с использованием большого числа заражённых устройств
DoS	Локальные атаки отказа в обслуживании	32 980 194	Вредоносные воздействия, инициируемые ограниченным числом источников и приводящие к нарушению доступности сервисов
Keylogging	Сбор нажатий клавиш	1 469	Активность программ-кейлоггеров, направленная на несанкционированное получение учётных данных и иной чувствительной информации
Data theft	Кража данных	118	Сетевые операции по изъятию конфиденциальной информации с компрометированных узлов и её передаче злоумышленнику

Несмотря на значительный объём и высокую реалистичность IoT-трафика, датасет характеризуется критическим дисбалансом классов, при котором атакующая активность занимает практически весь объём данных, а легитимный трафик представлен минимально, что ограничивает его применимость для обучения универсальных моделей IDS [6].

Дальнейшее развитие комплексных наборов данных было реализовано в датасете ToN-IoT, содержащем не только сетевой трафик, но и журналы регистрации событий, телеметрию устройств и диагностические данные. Общий объём датасета превышает 22 млн записей, а структура сетевой части представлена в табл. 6 [7].

Данный набор данных предоставляет уникальные возможности для исследования

атак в распределённых IoT-средах, однако высокая шумность данных и слабая сопоставимость с традиционными корпоративными сетями существенно ограничивают его использование в классических задачах обнаружения атак [7].

Наиболее актуальным среди рассмотренных является датасет NF-UQ-NIDS-v2, разработанный в 2022 году. Он был создан с учётом выявленных недостатков предыдущих наборов данных и ориентирован на формирование современного, масштабного и сбалансированного обучающего набора. Датасет включает около 75 млн записей сетевого трафика, распределённых между двадцатью классами атак и легитимной активностью. Его структура приведена в табл. 7 [8].

Таблица 6

Структура и распределение классов атак в датасете ToN-IoT

Класс	Значение класса	Количество записей	Описание
Backdoor	Атаки с использованием закладочных механизмов	508 116	Использование заранее внедрённых механизмов скрытого доступа к устройствам и сервисам интернета вещей
DoS	Атаки отказа в обслуживании	3 375 328	Попытки вывести из строя узлы IoT-инфраструктуры путём перегрузки каналов связи или вычислительных ресурсов
DDoS	Распределённые атаки отказа в обслуживании	6 165 008	Координированные воздействия, исходящие от большого числа IoT-устройств и направленные на парализацию работы целевых ресурсов
Injection	Инъекционные атаки	452 659	Встраивание произвольных команд и данных в протоколы и прикладные запросы, обслуживающие IoT-устройства
MITM	Атаки типа «человек посередине»	1 052	Перехват и возможная модификация сетевого трафика между узлами для получения или изменения передаваемых данных
Scanning	Разведывательно-сканирующая активность	7 140 161	Массовое сканирование адресного пространства и портов с целью идентификации уязвимых устройств и сервисов
Ransomware	Крипто-вымогательская активность	72 805	Блокирование или шифрование данных на IoT-устройствах с последующим требованием выкупа
Password	Атаки на механизмы аутентификации	1 718 568	Попытки подбора или перехвата паролей и иных аутентификационных данных
XSS	Межсайтовый скриптинг	2 108 944	Внедрение вредоносного сценарного кода в веб-интерфейсы управления IoT-системами
Normal	Легитимный сетевой трафик	796 380	Корректные сетевые взаимодействия в рамках штатной эксплуатации IoT-платформ

Таблица 7

Структура и распределение классов атак в датасете NF-UQ-NIDS-v2

Класс	Значение класса	Количество записей	Описание
Benign	Легитимный сетевой трафик	25 165 295	Сетевые соединения и пакеты, соответствующие политикам безопасности по содержанию и временным характеристикам
DDoS	Распределённые атаки отказа в обслуживании	21 748 351	Координированная генерация избыточного трафика с множества узлов с целью исчерпания ресурсов целевых сервисов
Reconnaissance	Разведывательно-сканирующая активность	2 833 778	Систематический сбор информации о топологии сети, активных хостах и доступных сервисах
Injection	Инъекционные атаки	684 897	Встраивание вредоносных команд или данных в прикладные или протокольные запросы

Продолжение табл. 7

Класс	Значение класса	Количество записей	Описание
DoS	Локальные атаки отказа в обслуживании	1 787 555	Воздействия, иницируемые ограниченным числом источников и приводящие к временному нарушению доступности сервисов
Brute Force	Атаки грубого подбора	123 892	Последовательный перебор реквизитов доступа без использования дополнительных знаний о системе
Password	Атаки на механизмы аутентификации	1 153 223	Подбор, перехват или повторное использование аутентификационных данных
XSS	Межсайтовый скриптинг	2 455 020	Внедрение вредоносного сценарного кода в веб-страницы с последующим выполнением на стороне клиента
Infiltration	Атаки проникновения	11 681	Сетевые действия, ведущие к внедрению и закреплению вредоносного ПО во внутреннем сегменте сети
Exploits	Эксплуатация уязвимостей	31 551	Инициирование выполнения кода или изменения конфигурации за счёт известных слабостей ПО
Scanning	Сетевое сканирование	3 781 419	Массовые попытки установления соединений для выявления открытых портов и сервисов
Backdoor	Закладочные механизмы	18 878	Организация скрытого удалённого доступа через ранее внедрённые механизмы
Bot	Ботнет-активность	14 907	Взаимодействия с управляющими центрами ботнетов и трафик, генерируемый для атак
Generic	Универсальные криптографические атаки	18 860	Воздействия на криптографические механизмы без привязки к конкретному приложению
Shellcode	Внедрение shell-кода	1 427	Передача и исполнение компактных фрагментов машинного кода
MITM	Атаки типа «человек посередине»	7 723	Перехват и возможная модификация трафика между легитимными узлами
Worms	Компьютерные черви	184	Самораспространяющиеся вредоносные программы, использующие сетевые уязвимости
Ransomware	Программы-шифровальщики	3 425	Активность, связанная с заражением, шифрованием данных и взаимодействием с серверами управления

NF-UQ-NIDS-v2 сочетает большой объём данных, актуальные атакующие сценарии и высокую равномерность распределения классов. В отличие от датасетов серии CIC, редкие типы атак представлены в объёмах, достаточных для обучения нейросетевых моделей. Кроме того, в набор включены классы угроз, отсутствующие в более ранних датасетах,

такие как ransomware, MITM, сложные инъекционные и backdoor-атаки [8].

Сравнительный анализ рассмотренных датасетов приведён в табл. 8, где они сопоставлены по критериям объёма, номенклатуры атак, соответствия современным угрозам, степени дисбаланса и реалистичности моделируемого трафика [1].

Таблица 8

Сравнительная характеристика открытых датасетов сетевого трафика для задач обнаружения и классификации кибератак

Датасет	Объём данных	Номенклатура атак	Соответствие современным угрозам	Степень дисбаланса классов	Реалистичность трафика
CICIDS2017	Средний	Средняя	Средняя	Высокая	Высокая
CICIDS2018	Средний	Средняя	Средняя	Очень высокая	Высокая
CSE-CIC-IDS2018	Средний	Средняя	Средняя	Высокая	Средняя
UNSW-NB15	Средний	Средняя	Средняя	Низкая	Средняя
BoT-IoT	Очень высокий	Низкая (доминирование IoT-атак)	Средняя	Экстремально высокая	Средняя
ToN-IoT	Высокий	Высокая	Высокая	Высокая	Средняя
NF-UQ-NIDS-v2	Очень высокий	Очень высокая	Очень высокая	Относительно низкая	Высокая

Сравнительный анализ показывает, что большинство ранних IDS-датасетов характеризуются либо выраженным дисбалансом классов, либо ограниченной номенклатурой атак, либо недостаточным соответствием современным условиям эксплуатации сетевых инфраструктур. Датасеты, ориентированные на IoT-среды, обладают высокой специализацией, но не обеспечивают универсальности, необходимой для обучения обобщённых классификационных моделей.

В этом контексте NF-UQ-NIDS-v2 демонстрирует наиболее сбалансированное сочетание объёма данных, разнообразия атакующих сценариев, актуальности угроз и реалистичности сетевого трафика. Эти свойства обосновывают выбор данного датасета в качестве основного источника обучающих данных для построения классификационной модели, основанной на шаблонах CAPEC, и обеспечивают надёжность и воспроизводимость получаемых результатов [8].

Методика формирования набора детектируемых шаблонов атак

Формирование набора детектируемых шаблонов атак является ключевым этапом подготовки данных, определяющим как архитектуру подсистемы сбора и предварительной обработки информации, так и содержание обучающей выборки для

классификационной модели. В рамках разрабатываемой системы сбор данных осуществляется по двум логически разделённым направлениям, каждое из которых ориентировано на выявление различных проявлений атакующих сценариев [9].

Первое направление связано с подготовкой данных для модели машинного обучения и опирается исключительно на анализ сырого сетевого трафика. В данном случае используются признаки, формируемые непосредственно на основе параметров сетевых соединений и статистических характеристик потоков, которые могут быть представлены в числовом виде и использованы при обучении классификационной модели. Второе направление включает анализ вспомогательных источников данных, таких как системные и прикладные журналы регистрации событий, телеметрия и сигнатуры IDS, данные DNS, TLS-отпечатки JA3, сведения DHCP, ARP, SNMP и другие событийные каналы. Эти источники позволяют фиксировать дополнительные признаки атак, не всегда выраженные на уровне сетевого трафика [9].

Разделение направлений обработки обусловлено тем, что модель машинного обучения должна опираться исключительно на те данные, которые формируются непосредственно в сетевом трафике и

поддаются формализации в виде устойчивых статистических и поведенческих признаков. В то же время модуль сбора и анализа вспомогательных источников ориентирован на выявление более широкого спектра проявлений атак, включая протокольные аномалии, сбои в работе сервисов, нарушения функционирования приложений и нетипичные последовательности сетевых запросов. В результате набор детектируемых шаблонов атак должен охватывать как сценарии, выявляемые на основе сетевого трафика, так и сценарии, наблюдаемые через дополнительные средства мониторинга [1].

Критерием включения шаблона CAPEC в набор детектируемых является наличие устойчивых и интерпретируемых технических признаков, наблюдаемых в одном или нескольких источниках данных, доступных системе. Если реализация атакующего паттерна приводит к изменению структуры пакетов, аномалиям параметров протоколов, формированию специфических последовательностей соединений, появлению характерных сигнатур IDS либо отражается в журналах регистрации событий или телеметрии, такой шаблон рассматривается как доступный для последующей идентификации и классификации. Шаблоны атак, не оставляющие наблюдаемых следов в сетевых или событийных источниках, исключаются из набора как недетектируемые [2].

Сформированный набор детектируемых шаблонов атак имеет двойное назначение. С одной стороны, он определяет перечень классов атак, которые могут быть представлены в обучающей выборке и использованы при обучении модели машинного обучения. С другой стороны, данный набор задаёт структуру атакующих сценариев, подлежащих выявлению в модуле сбора и предварительной обработки данных, что обеспечивает согласованность между двумя потоками анализа информации. Таким образом достигается единая методологическая основа, обеспечивающая сопоставимость данных, получаемых из сетевого трафика и вспомогательных источников [9].

В табл. 9 приведён фрагмент итоговой таблицы детектируемых шаблонов CAPEC с указанием источников наблюдения и обоснованием их включения в набор данных [2].

Сформированный набор детектируемых шаблонов охватывает порядка 40 % от общего числа шаблонов, представленных в классификаторе CAPEC. Данная доля отражает количество шаблонов, для которых возможно выделение устойчивых и интерпретируемых технических признаков на основе анализа сетевого трафика и событийных данных. Остальные шаблоны CAPEC ориентированы на высокоуровневые или организационные сценарии атак и не могут быть использованы для автоматизированной детекции в рамках выбранных источников данных.

Подготовка обучающих данных для классификационной модели

Подготовка обучающих данных для классификационной модели является завершающим этапом формирования методической основы разрабатываемой системы и опирается на результаты анализа таксономии CAPEC, выбранного датасета и сформированного набора детектируемых атак. Ключевым методологическим принципом данного этапа является сопоставление каждой записи исходного датасета конкретному шаблону CAPEC, что обеспечивает логическую непрерывность между формализованным описанием атакующих сценариев и их фактическими проявлениями в сетевом трафике [2].

Данный принцип приобретает особую значимость при использовании датасета NF-UQ-NIDS-v2, который содержит набор эмпирических классов атак, таких как сканирование, DoS/DDoS-воздействия, эксплуатация уязвимостей, аномальный трафик и другие формы нарушений. Эти классы формировались в рамках конкретных исследовательских сценариев и не опираются на единую формализованную модель угроз, что при их прямом использовании может приводить к частичной потере семантики атак и формированию неоднородных классов [8].

Таблица 9

Фрагмент набора детектируемых шаблонов атак CAPEC и источники их наблюдения

CAPEC ID	Название	Краткое описание	Источник наблюдения	Основание включения
CAPEC-33	Разведка информационно й системы (HTTP Request Smuggling)	Шаблон атаки CAPEC, описывающий приём манипуляции структурой HTTP-запросов с целью обхода механизмов обработки запросов на сервере	PCAP, NetFlow, IDS	Включён, поскольку приводит к формированию характерных сетевых потоков и сигнатур IDS, позволяющих выявлять атаку на основе анализа сетевого трафика и событий IDS
CAPEC-34	Контрабанда HTTP-ответов (HTTP Response Splitting)	Шаблон атаки, связанный с внедрением дополнительных заголовков или ответов путём некорректной обработки HTTP-ответов	Zeek	Включён, так как его признаки могут быть выявлены средствами Zeek на уровне анализа прикладных сетевых протоколов
CAPEC-35	Перебор учётных данных путём массовых проверок (Credential Stuffing)	Шаблон атаки, описывающий автоматизированный перебор учётных данных с использованием ранее скомпрометированных наборов логинов и паролей	Логи приложений (Web, API, DB, Syslog)	Включён, поскольку отражается в журналах аутентификации и прикладных событиях, что позволяет выявлять атаку на уровне бизнес-логики
CAPEC-36	Использование недокументированных интерфейсов	Шаблон атаки, связанный с обращением к скрытым или не предназначенным для публичного использования функциям приложений	Логи приложений (Web, API, DB, Syslog)	Включён, так как проявляется в аномальных запросах и ошибках, фиксируемых в журналах приложений и системных логах

В отличие от этого, таксономия CAPEC предоставляет систематизированное описание механизмов атак, основанное на концептуальных паттернах и подтверждённое многолетней практикой анализа киберугроз. Сопоставление каждого фрагмента трафика из NF-UQ-NIDS-v2 с конкретным шаблоном CAPEC позволяет внести в исходный датасет недостающий уровень формализации. В результате каждый пример обучающей выборки начинает представлять не абстрактный тип атаки, а конкретный атакующий сценарий, описанный на уровне методов, последовательностей действий и характерных технических признаков [2].

Установление связи между эмпирическими классами атак, представленными в NF-UQ-NIDS-v2, и формализованными шаблонами CAPEC осуществляется посредством сопоставления каждого класса датасета множеству соответствующих паттернов атак. Такой подход позволяет уточнить семантическое содержание исходных меток и определить, какие именно механизмы угроз лежат в основе наблюдаемого сетевого поведения. На данном этапе выполняется переход от обобщённых категорий, таких как Brute Force, DoS или Reconnaissance, к конкретным шаблонам CAPEC, что обеспечивает полноту

и интерпретируемость последующей разметки каждого сетевого потока [2]. соответствие между обобщёнными категориями атак датасета и множеством

Результаты данного сопоставления конкретных шаблонов CAPEC, представлены в табл. 10 и отражают описывающих механизмы реализации атак.

Таблица 10

Сопоставление классов атак датасета NF-UQ-NIDS-v2 с шаблонами классификатора CAPEC

Класс атак NF-UQ-NIDS-v2	Идентификаторы шаблонов CAPEC
Перебор паролей с помощью грубой силы (Brute Force)	CAPEC-112, CAPEC-49, CAPEC-16, CAPEC-565, CAPEC-70, CAPEC-600, CAPEC-560, CAPEC-653
Атаки межсайтового скриптинга (XSS)	CAPEC-63, CAPEC-592, CAPEC-86, CAPEC-209, CAPEC-245, CAPEC-648
Инъекционные атаки (Injection)	CAPEC-66, CAPEC-242, CAPEC-248, CAPEC-88, CAPEC-250, CAPEC-83, CAPEC-84, CAPEC-228, CAPEC-586, CAPEC-6, CAPEC-624, CAPEC-640
Атаки отказа в обслуживании (DoS)	CAPEC-125, CAPEC-482, CAPEC-486, CAPEC-487, CAPEC-488, CAPEC-469, CAPEC-490, CAPEC-495, CAPEC-496
Разведка и сбор информации (Reconnaissance)	CAPEC-118, CAPEC-169, CAPEC-116, CAPEC-192, CAPEC-127, CAPEC-310
Сканирование сетевой инфраструктуры (Scanning)	CAPEC-292, CAPEC-285, CAPEC-299, CAPEC-297, CAPEC-300, CAPEC-287, CAPEC-308, CAPEC-303, CAPEC-309, CAPEC-330
Атаки типа «человек посередине» (MITM)	CAPEC-94, CAPEC-158, CAPEC-157, CAPEC-384, CAPEC-466, CAPEC-151, CAPEC-216, CAPEC-102
Закладочные механизмы (Backdoor)	CAPEC-443, CAPEC-523, CAPEC-401, CAPEC-446, CAPEC-511
Ботнет-активность (Bot)	CAPEC-682, CAPEC-490, CAPEC-482, CAPEC-486
Эксплуатация уязвимостей (Exploits)	CAPEC-100, CAPEC-9, CAPEC-10, CAPEC-24, CAPEC-46, CAPEC-47, CAPEC-92, CAPEC-26, CAPEC-29, CAPEC-21, CAPEC-22, CAPEC-160, CAPEC-172
Кража данных (Theft)	CAPEC-117, CAPEC-158, CAPEC-157, CAPEC-37, CAPEC-402
Внедрение и исполнение кода (Shellcode)	CAPEC-100, CAPEC-153, CAPEC-642
Компьютерные черви (Worms)	CAPEC-442, CAPEC-523
Шифровальщики (Ransomware)	CAPEC-549, CAPEC-163, CAPEC-17
Инструменты генерации тестовых воздействий (Fuzzers)	CAPEC-116, CAPEC-272, CAPEC-276, CAPEC-278, CAPEC-192, CAPEC-80, CAPEC-223
Распределённые атаки отказа в обслуживании (DDoS)	CAPEC-125, CAPEC-482, CAPEC-486, CAPEC-487, CAPEC-488, CAPEC-469, CAPEC-490, CAPEC-495, CAPEC-496
Проникновение в инфраструктуру (Infiltration)	CAPEC-437, CAPEC-511, CAPEC-446, CAPEC-523, CAPEC-560, CAPEC-662
Атаки на механизмы аутентификации (Password)	CAPEC-112, CAPEC-49, CAPEC-16, CAPEC-565, CAPEC-70, CAPEC-600, CAPEC-560, CAPEC-653

Представленное сопоставление демонстрирует, что каждый эмпирический класс атак NF-UQ-NIDS-v2 включает несколько различных шаблонов CAPEC, отражающих разнообразие механизмов реализации угроз в рамках одной категории сетевого поведения. Такой подход позволяет избежать избыточного укрупнения классов и обеспечивает более точную и интерпретируемую разметку обучающих данных. Кроме того, использование шаблонов CAPEC в качестве целевых классов

создаёт основу для построения классификационной модели, ориентированной не на абстрактные типы атак, а на конкретные сценарии действий злоумышленника [2].

После выполнения процедуры обогащения структура данных приобретает формат, пригодный для непосредственного использования в процессе обучения классификационной модели. Итоговый формат строки обучающего набора приведён в табл. 11 [2].

Таблица 11

Структура записи обучающего набора данных для классификационной модели

Поле	Значение	Назначение поля
IP-адрес отправителя	...	IP-адрес источника, с которого был получен сетевой пакет или инициирован сетевой поток
IP-адрес получателя	...	IP-адрес целевого узла, с которым устанавливается сетевое взаимодействие
Порт отправителя	...	Номер порта источника, используемого при формировании сетевого соединения
Порт получателя	...	Номер порта назначения, определяющий тип сервиса или приложения
Номер протокола	...	Идентификатор транспортного или сетевого протокола, используемого в соединении
Длительность потока	...	Временной интервал существования сетевого потока
Количество пакетов	...	Общее число пакетов, переданных в рамках потока
Объём переданных данных	...	Суммарный объём переданных данных в байтах
...	...	Набор вычисленных и агрегированных статистических и поведенческих признаков сетевого потока
CAPEC_ID	CAPEC-XXX	Идентификатор шаблона атаки согласно классификатору CAPEC, используемый в качестве целевой метки класса

Представленная структура обеспечивает логическую связь между низкоуровневыми характеристиками сетевого трафика и формализованным описанием атакующих сценариев. Использование идентификатора CAPEC в качестве целевой метки класса позволяет обучать модель машинного обучения на интерпретируемых сценариях атак, а не на абстрактных типах трафика. Это создаёт основу для построения классификационной модели, результаты работы которой могут быть напрямую сопоставлены с таксономией CAPEC и использованы в аналитических и практических задачах обеспечения информационной безопасности [2].

Заключение

В статье разработаны и обоснованы теоретические и методические основы формирования обучающих данных для систем автоматизированного обнаружения и классификации кибератак на основе комплексного анализа сетевого трафика и журналов событий. Проведённый анализ таксономии CAPEC позволил сформировать структурированный набор детектируемых шаблонов атак, опирающихся на устойчивые

и интерпретируемые признаки, наблюдаемые в доступных источниках данных, что обеспечило формализацию процессов разметки и определение границ применимости разрабатываемого подхода [1].

Ключевым результатом работы стало методически обоснованное разграничение шаблонов CAPEC на используемые для обучения моделей машинного обучения и выявляемые программными методами на основе анализа событийных и телеметрических данных. Такое разделение позволило согласовать использование различных источников информации и обеспечить корректное распределение функциональных ролей между компонентами системы обнаружения атак. Практическое применение вспомогательных средств мониторинга, включая анализ сетевого трафика, журналов регистрации событий, телеметрии и сигнатурных данных IDS, обеспечило расширение перечня обнаруживаемых атакующих сценариев по сравнению с подходами, основанными на одном источнике данных [10].

В ходе исследования показано, что сформированный набор детектируемых

шаблонов охватывает порядка 40 % от общего числа сценариев, представленных в классификаторе CAPEC, что отражает реальную долю атак, поддающихся автоматизированному обнаружению на основе технических индикаторов. Такое покрытие демонстрирует практическую применимость предложенной методики и одновременно подчёркивает необходимость осознанного отбора шаблонов при проектировании систем обнаружения вторжений.

Сформированный обучающий набор представляет собой согласованный и воспроизводимый массив данных, в котором каждая запись сопоставлена конкретному шаблону CAPEC, а общий состав примеров отражает как реальные характеристики сетевого трафика, так и формализованное описание атакующих сценариев. Полученные результаты могут быть использованы при разработке и внедрении систем обнаружения и классификации кибератак в корпоративных, облачных и распределённых сетях, а также служат методической основой для последующего построения, обучения и оценки классификационных моделей, ориентированных на интерпретируемое и сценарно-ориентированное выявление угроз.

Список литературы

1. Sommer R., Paxson V. Outside the closed world: On using machine learning for network intrusion detection // *Proceedings of the IEEE Symposium on Security and Privacy*. 2010. P. 305–316.
2. MITRE Corporation. Common Attack Pattern Enumeration and Classification (CAPEC) [Электронный ресурс]. URL: <https://capec.mitre.org> (дата обращения: 16.12.2025).
3. Sharafaldin I., Toward generating a new intrusion detection dataset and intrusion traffic characterization / I. Sharafaldin, A.H. Lashkari, A.A. Ghorbani // *Proceedings of the International Conference on Information Systems Security and Privacy (ICISSP)*. 2018. P. 108–116.
4. Sharafaldin I. A detailed analysis of the CICIDS2017 data set/ I. Sharafaldin, A.H. Lashkari, A.A. Ghorbani // *Information Systems Security and Privacy*. 2019. P. 1–14.
5. Moustafa N., Slay J. UNSW-NB15: a comprehensive data set for network intrusion detection systems // *Proceedings of the Military Communications and Information Systems Conference (MilCIS)*. IEEE, 2015.
6. Koroniotis N. Towards the development of realistic botnet dataset in the Internet of Things for network forensic analytics / N. Koroniotis, N. Moustafa, E. Sitnikova, B. Turnbull // *Future Generation Computer Systems*. 2019. Vol. 100. P. 779–796.
7. Moustafa N. ToN-IoT: The realistic IoT network traffic dataset for intrusion detection systems / N. Moustafa, B. Turnbull, K.-K. R. Choo // *IEEE Access*. 2020. Vol. 8. P. 177333–177351.
8. Moustafa N. An ensemble intrusion detection technique based on proposed statistical flow features for protecting network traffic of internet of things / N. Moustafa, B. Turnbull, K.-K. R. Choo // *IEEE Internet of Things Journal*. 2019. Vol. 6, No. 3. P. 4815–4830.
9. Sarhan M., Layeghy S., Portmann M. NF-UQ-NIDS-v2: A benchmark dataset for network intrusion detection systems // *arXiv preprint*. 2022. arXiv:2201.01756.
10. García-Teodoro P. Anomaly-based network intrusion detection: Techniques, systems and challenges / P. García-Teodoro, J. Díaz-Verdejo, G. Maciá-Fernández, E. Vázquez // *Computers & Security*. 2009. Vol. 28, No. 1–2. P. 18–28.

Финансовый университет при Правительстве Российской Федерации
Financial University under the Government of the Russian Federation

Воронежский государственный технический университет
Voronezh State Technical University

Поступила в редакцию 22.11.2025

Информация об авторах

Васильченко Алексей Павлович – аспирант, Финансовый университет при Правительстве Российской Федерации, e-mail: rainichek@yandex.ru

Попова Елена Андреевна – студент, Воронежский государственный технический университет, e-mail: elpov0211@gmail.com

Жуков Никита Павлович – аспирант, Воронежский государственный технический университет, e-mail: znp8b00ff@gmail.com

Сотников Сергей Евгеньевич – студент, Воронежский государственный технический университет, e-mail: alexanderostapenkoias@gmail.com

**CYBER-ATTACK DETECTION AND CLASSIFICATION
BASED ON COMPREHENSIVE ANALYSIS OF NETWORK TRAFFIC
AND EVENT LOGS: A METHODOLOGY FOR GENERATING
TRAINING DATA AND A SET OF DETECTED PATTERNS**

A.P. Vasilchenko, E.A. Popova, N.P. Zhukov, S.E. Sotnikov

The article discusses the task of generating training data for automated detection and classification systems for cyber attacks based on a comprehensive analysis of network traffic and event logs. A method for selecting and structuring detectable attack patterns using the CAPEC taxonomy is proposed, providing formalization of data markup processes and defining the boundaries of the system's applicability. The differentiation of CAPEC templates into machine learning models used for training and those identified by software methods of event data analysis is substantiated. It is shown that the generated set of detectable patterns covers about 40% of the CAPEC list and allows you to create a reproducible training set focused on interpretable and scenario-oriented detection of cyber attacks.

Keywords: attack detection, attack classification, network traffic, event logs, CAPEC, training data.

Submitted 22.11.2025

Information about the authors

Alexey P. Vasilchenko – graduate student, Financial University under the Government of the Russian Federation, e-mail: rainichek@yandex.ru

Elena A. Popova – student, Voronezh State Technical University, e-mail: elpov0211@gmail.com

Nikita P. Zhukov – graduate student, Voronezh State Technical University, e-mail: znp8b00ff@gmail.com

Sergey E. Sotnikov – student, Voronezh State Technical University, e-mail: alexanderostapenkoias@gmail.com